

BTLO Challenge Report

Phishing Analysis — Email Forensics

Analyst	Abiral Timalina
Platform	Blue Team Labs Online (BTLO)
Category	Email / Phishing Forensics
Difficulty	Easy
Points	10
Tools Used	Kali Linux, grep, qprint, DomainTools WHOIS, URL2PNG

1. Scenario

A user received a phishing email and forwarded it to the SOC. The objective is to investigate the raw .eml file and its embedded content to extract key artifacts: sender and recipient details, originating infrastructure, and any malicious URLs or attachments.

2. Methodology

2.1 Initial Header Review

The .eml file was opened directly and its headers reviewed. The file turned out to be a non-delivery (bounce) notification wrapping the original phishing email as a nested message/rfc822 MIME attachment — a structure that required careful separation of the outer bounce headers from the original phishing message's headers to avoid misattributing sender/recipient data.

```
grep -in "Content-Type" "Website contact form submission.eml"
```

This identified the boundary of the embedded original message at the line containing Content - Type : message/rfc822, allowing the original headers to be isolated and reviewed directly.

2.2 Sender, Recipient, and Timing

The original phishing message headers showed a recipient of kinnar1975@yahoo.co.uk, sent via a compromised or abused hosting account (markgard) with X-Originating-IP: 103.9.171.10.

2.3 Reverse DNS Lookup

A WHOIS/reverse-DNS lookup was performed on the originating IP via whois.domaintools.com, resolving to c5s2-1e-syd.hosting-services.net.au, an Australian shared hosting provider (Synergy Wholesale Pty Ltd).

2.4 Extracting the Malicious URL

The email body was quoted-printable encoded, which broke the embedded URL across multiple soft-wrapped lines and prevented direct extraction with grep. The body was decoded first:

```
qprint -d "Website contact form submission.eml" > decoded.eml
grep -o 'https://[^ <>]*' decoded.eml
```

The decoded body revealed a "get rich quick" lure directing the recipient to a scam landing page hosted on Blogspot (Google Blogger).

2.5 Landing Page Verification

The extracted URL was submitted to URL2PNG to capture a rendered preview of the page without directly visiting it in a browser. The preview confirmed the blog had already been taken down by the hosting provider, displaying a "Blog has been removed" notice.

3. Findings

#	Question	Answer
1	Primary recipient of this email?	kinnar1975@yahoo.co.uk
2	Subject of this email?	Undeliverable: Website contact form submission
3	Date and time the email was sent?	18 March 2021 04:14
4	Originating IP?	103.9.171.10
5	Reverse DNS resolved host?	c5s2-1e-syd.hosting-services.net.au
6	Name of the attached file?	Website contact form submission.eml
7	URL found inside the attachment?	https://35000usdperwwekpdf.blogspot.sg?p=9swghttps://35000usdperwwekpdf.blogspot.co.il?o=0hnd
8	Service this webpage is hosted on?	Blogspot
9	URL2PNG heading text on the page?	Blog has been removed

4. Lessons Learned

- Bounce/non-delivery notifications can carry the original phishing message as a nested attachment — analysts should always check for embedded message/rfc822 MIME parts rather than assuming the outer headers belong to the actual sender/recipient.
- Quoted-printable encoding will break naive string searches on raw email bodies; decoding the body first (via qprint or an equivalent tool) is a necessary step before extracting URLs, IOCs, or other embedded content.
- Tools like URL2PNG allow safe visual verification of a suspected malicious page without directly navigating to it, which is useful even after a page has already been taken down.